ARTA Portal VAPT Remediation Validation Report

Target: ARTA Portal codebase and reachable local HTTP endpoints
Workspace: c:\xampp\htdocs\Arta-Portal
Validation date: 2026-06-01
Method: targeted static review, syntax validation, pattern sweep, and non-destructive HTTP validation on a local PHP server

Executive summary

The previously reported findings were re-tested after code changes and were successfully addressed in the current validation scope. Shared CSRF protection was added to the affected browser-triggered write actions, raw backend exception text was removed from the API sweep that previously leaked internals, anonymous full metadata endpoints now require authentication, and registration keeps working through a controlled anonymous lookup mode with minimal data. No critical, high, medium, or low finding from the prior report was reproduced in this remediation validation pass.

Risk Summary

Severity	Count	Notes
CRITICAL	0	No critical finding reproduced in the validated scope.
HIGH	0	No high-severity finding reproduced in the validated scope.
MEDIUM	0	No medium finding reproduced in the validated scope.
LOW	0	No low finding reproduced in the validated scope.
RESOLVED	6	Previously reported items that now validate as addressed.

Validated Remediations

RESOLVED Anonymous role administration remains blocked

Unauthenticated `POST /api/role/create_role.php` still returns `401 Authentication required`. The endpoint remains protected by role-based session checks and now also expects a CSRF token for authenticated browser requests.

RESOLVED Anonymous assignment user enumeration remains blocked

Unauthenticated `GET /api/assignment/get_users.php?type=office&id=1` still returns `401 Authentication required`. The previous user-directory exposure was not reproducible.

RESOLVED Password recovery behavior remains hardened

Forgot-password still returns a generic success response for unknown accounts and uses reset links instead of direct password replacement. Registration POST now also requires a valid CSRF token and reaches normal field validation when the token is supplied.

RESOLVED CSRF protection is now enforced on the affected browser write actions

The shared API guard now issues and validates session-backed CSRF tokens. The role-management and system-assignment pages were updated to send `X-CSRF-Token` headers on JSON POST requests, with retry-on-expiry handling. Registration was also updated to submit with a CSRF token.

RESOLVED Raw backend exception leakage was removed from the retested API sweep

A follow-up source sweep for `display_errors = 1`, wildcard CORS on exposed APIs, `error_details`, and direct `$e->getMessage()` responses in the API tree returned no matches after remediation. The previously leaking registration, lookup, assignment, systems, and list endpoints now return generic client-facing errors.

RESOLVED Anonymous full organization metadata exposure was reduced to controlled lookup mode

The office, division, unit, and designation endpoints now require authentication for the full dataset. Anonymous callers only receive the minimal registration lookup dataset when `lookup=1` is explicitly used. Validation showed `401` for anonymous full office access and `200` for anonymous `lookup=1` requests returning minimal records.

Validation Evidence

Check	Result
`GET /api/auth/get_csrf.php`	`200` with session-backed token payload
`GET /api/offices/get_offices.php?lookup=1&limit=1`	`200` with minimal office lookup payload
`GET /api/offices/get_offices.php?limit=1` without authentication	`401 Authentication required`
`POST /api/auth/register.php` without CSRF token	`419` CSRF failure
`POST /api/auth/register.php` with valid CSRF token but incomplete body	`400` field validation response, confirming business logic is still reachable
PHP syntax validation on touched files	No syntax errors detected

Integration Observation

The Portal-to-AMS SSO handoff remains on the same `/sso-login?token=...` contract and still succeeds on a fresh first-use token. The remaining integration issue observed during separate testing is AMS treating expected validator failures such as `409 Token already used` as a generic `500`. That is an AMS-side error-handling concern rather than a Portal regression.

Conclusion

In the retested scope, the findings from the prior ARTA Portal VAPT report were addressed without introducing syntax errors in the touched files. This report is a remediation validation snapshot rather than a full replacement for broader future testing, but the specific issues previously raised in this workflow were not reproduced after the fixes.

Generated locally for the ARTA Portal workspace on 2026-06-01.